

Sri Lanka Institute of Information Technology



Group Assignment No. 01

ISMS Core Documentation

Submitted by: Group ID_30

Enterprise Standards for Information Security – IE3102

B.Sc. (Hons) in Information Technology

Group Details

Project Title: **ISMS Core Documentation**

	Name	Registration Number	Email
1	Prasad M.M.W	IT23252868	IT23252868@my.sliit.lk
2	Weerakumara K.D	IT23202436	IT23202436@my.sliit.lk
3	Kumarage T.D.S.D.	IT23292918	IT23292918@my.sliit.lk
4	Lahiru W.T	IT23253612	IT23253612@my.sliit.lk

Table of Contents

1. Introduction

2. ISMS Core Documentation Pack

2.1 Scope Statement

2.1.1 Definition of ISMS Boundaries

2.1.2 Included Processes, Assets, Locations, and Departments

2.1.3 Exclusions and Rationale

2.1.4 Alignment with Organizational Objectives and Risk Appetite

2.2 Information Security Policy

2.2.1 Purpose and Objectives

2.2.2 Commitment From Top Management

2.2.3 Information Security roles and responsibilities

2.2.4 High Level Principles Security and Compliance Requirements

2.2.5 Implementation, Monitoring, and Improvement of Standards

2.3 Statement of Applicability (SoA)

2.3.1 Selected Annex A Controls and Justification

2.3.2 Excluded Controls and Justification

2.3.3 Mapping to Identified Risks and Regulations

2.4 Risk Treatment Plan

2.4.1 Prioritized Risks

2.4.2 Treatment Strategies Selected

2.4.3 Timelines and Responsibilities

2.4.4 Monitoring, Review, and Effectiveness Evaluation

3. Conclusion

1. Introduction and Overview

DSM IT (Pvt) Ltd's Information Security Management System (ISMS) Core Documentation Pack has been created to provide a planned, structured, and systematic way of managing information security in accordance with ISO/IEC 27001:2022. DSM IT (Pvt) Ltd is responsible for its clients' information, enterprise applications, cloud resources, and digital assets that are core to its business operations and services as an IT solutions and services provider. It is therefore important to ensure clients' information is kept confidential, the data integrity is maintained, and the availability of this information is ensured when delivering services to clients. This is crucial in the maintenance of trust with clients, compliance obligations, and the company's long-term growth and sustainability.

This documentation will be key to the development and implementation of an effective and resilient ISMS, which will demonstrate in the documentation the area and scope of ISMS, security policies, and the adopted Annex A controls, and do a thorough risk treatment plan. The sections have been specifically created to align with the organizations strategy, risk appetite and operational requirements, ensuring information security management is not purely a compliance exercise, but can enable business potential.

Furthermore, the ISMS Core Documentation illustrates the commitment of DSM IT (Pvt) Ltd management who provide sufficient resources, allocate responsibilities, and reinforce security awareness across the organization and all personnel levels and departments. In this way, security is woven into the day-to-day operation of the company, thus requiring employees, contractors, and third parties to contribute towards safeguarding the workplace and promoting security practices follow throughout their day.

The ISMS Core Documentation Pack should ultimately serve as a progressive, ongoing improvement framework for our management at DSM IT (Pvt) Ltd who will regularly monitor, review, and update to meet emerging risks, technologies, and regulation change to establish adequate resiliency in the delivery of our safe and reliable IT services to clients, including but not limited to protecting against threats, disruptions to the business and its operations.

2. ISMS Core Documentation Pack

2.1 Scope Statement

The Information Security Management System (ISMS) for DSM IT (Pvt) Ltd provides the structure to control information security risks and protect the company's most sensitive information. The scope of the ISMS defines the limits, coverage and areas of focus to achieve alignment with the requirements of ISO/IEC 27001:2022.

2.1.1 Definition of ISMS Boundaries

The scope of the ISMS includes all information assets, processes and systems that are utilized to deliver IT solutions and services by DSM IT (Pvt) Ltd. It covers physical and digital perimeters for both on-premises and cloud resources, enterprise applications, employee devices and data storage. The definition shall also include all of the organization's workers, whether they are staff, contractors, or third-party suppliers who have access to the organisation's information systems.

2.1.2 Included Processes, Assets, Locations, and Departments

- Processes: Software development, IT operations, cloud operations, support, maintenance, incidents, and BC.
- Assets: Servers, networking, software, databases, clients and endpoint devices for employees.
- Places: Head office, development centers and all other remote working locations provided / approved by the Company.
- Departments involved: IT operations, software development, client services, and support representatives who process sensitive info.

2.1.3 Exclusions and Rationale

Some processes or areas can be out of the scope of the ISMS if they do not pose IS risk or are not really addressed by the requirements and the objectives of ISO 27001. For example:

- Non-sensitive administration activities.
- Operations for which the external partner is solely responsible, but which is not under the direct control of DSM IT (Pvt) Ltd. (Contractual obligations typically would specify security responsibilities)

There is a rationale for these exclusions, to remain focused on the areas of the view with the most risk exposure and business impact.

2.1.4 Alignment with Organizational Objectives and Risk Appetite

The Scope of ISMS is compatible with DSM IT (Pvt) Ltd's objectives to secure client data, provide continuity of critical business services and to comply with laws and regulations. The boundaries established ensure that resources are effectively deployed to maintain the level of management of information security risks that is in line with the organization's appetite for such risks and its strategic and business objectives.

2.2 Information Security Policy

The Information Security Policy states DSM IT (Pvt) Ltd.'s pledge on the protection of their information assets and on the business/operational side for the paramount need - the preservation of the confidentiality, integrity, and availability of their information and information processing facilities against threats and vulnerabilities and related risks in accordance with the requirements of ISO/IEC 27001:2022 based standards. This policy forms the basis of the company's ISMS and helps provide direction to all employees, contractors and interested parties to ensure a secure information environment is maintained.

2.2.1 Purpose and Objectives

The Information Security Policy of DSM IT (Pvt) Ltd is the foundation of the organization's Information Security Management System (ISMS). The policy is the official document that links the organization's commitment to protecting its information assets, and to provide a framework to support employees, contractors, and stakeholders in protecting sensitive information, where appropriate. The policy establishes the principles of the organization's responsibilities, and its objectives, in relation to the confidentiality, integrity, and availability of information by the organization.

Protection Against Unauthorized Access

- The policy clearly aims at stopping unauthorized use or misuse of customer and company information.
- These comprise security measures that include access control, authentication, and monitoring solutions to make sure that only authorized people are able to access sensitive data.
- By putting those safeguards in the policy, DSM IT (Pvt) Ltd proves that it plans ahead for risks and complies with ISO/IEC 27001:2022 standards.

Systematic Risk Evaluation and Mitigation

- The policy applies a systematic approach for the detection, evaluation, and control of information security threats.

- It requires ongoing assessment and prioritization of threats, both high and low, to make sure that high threats are handled promptly.
- This systematic approach ensures that security practices within the organisation are according to international best practices and allows a thorough Risk Treatment Plan to be built.

Support for Business Goals and Compliance

- The policy supports information security making a direct contribution to organizational goals, for example, operational effectiveness, customer trust, and regulatory adherence.
- Through the incorporation of security solutions within day-to-business activities, DSM IT (Pvt) Ltd reduces threats and ensures productivity and therefore enables strategic development.

Preservation of Confidentiality, Integrity, and Availability (CIA)

- The policy clearly defines the intent for preserving information assets' confidentiality, integrity, and availability.
- This ensures that sensitive information is never disclosed in an illegitimate format, retains its reliability and integrity, and is accessible to legit individuals as needed.

Legal and Regulatory Adherence

- The policy requires the organisation to comply with all appropriate laws, regulations, and contractual obligations, for instance, data protection acts, for example, PDPA.
- Through formalizing compliance within the policy, DSM IT (Pvt) Ltd provides a yardstick for audits and continuous improvement for the Information Security Management System (ISMS).

2.2.2 Commitment From Top Management

The Information Security Policy of DSM IT (Pvt) Ltd is significantly strengthened by the steadfast commitment of its top management. This commitment unequivocally demonstrates that information security is not simply a set of procedural requirements or technical tasks, but rather, a strategic organizational priority, which is supported at the very highest level of the organization. Top management ensures that the policy is being effectively implemented, maintained, and improved by engaging in the organization's culture and decision making to embed security at the organizational level. In this regard, the policy provides a strong foundation for the Information Security Management System (ISMS) by embedding a security focus within the organization.

1. Provision of Adequate Resources

An essential component of the Information Security Policy is the assurance of sufficient resources (financial, technological, and human resources) are allocated to support the ISMS. Top management ensures that there are appropriate tools, systems, software, and trained personnel available for the effective implementation, operation, and maintenance of the ISMS. In doing so, the organization recognizes its commitment to protecting sensitive information, reducing risk, and providing a secure operational environment for all departments, locations and functions; the Policy then ensures resource allocation becomes a strategic enabler for information security excellence.

2. Promotion of Security Awareness

The Information Security Policy also consists ensuring security awareness is promoted to create a security-conscious organizational culture. Management is engaged in the promotion of awareness programs, seminars and workshops, training, and ongoing education of employees, contractors, and stakeholders. These programs support each individual's added responsibilities for protecting the company's information assets. This allows for the Information Security Policy principles to be included in normal activities; reinforcing understanding, reducing human-based risks while encouraging regular behaviours in a proactive security posture.

3. Implementation and Continuous Review of Security Policies

The stripes will be forwarded to these space boxes. The policy is intended to remain dynamic as opposed to static. Top management is responsible for regularly reviewing the Information Security Policy, ensuring compliance with the ISO/IEC 27001:2022, management objectives, legal, regulatory and contractual obligations. By including this area into your pre-thoughts section, it can enhance the continuous improvement of the ISMS. In the ever-changing times with the ever growing number of threats and risks, making sure the ISMS remains relevant and effective in protecting any sensitive information and is continuing to contribute to the business objectives is prudent decision making.

2.2.3 Information Security roles and responsibilities

- Senior Management: Endorse policies and allocate resources and monitor the success of the ISMS.
- Information Security Officer / ISMS Team The ISMS team is responsible for Establishing and reviewing the controls Monitoring compliance and reporting information security incidents.

- All Employees and Contractors to, follow security rules, report information security incidents and to be aware and to adopt secure behaviours in their work.

2.2.4 High Level Principles Security and Compliance Requirements

- Manage security based on risk and proportional to the harm that could result if risk is realized.
- Secure access controls, encryption and handling of sensitive data.
- Comply with applicable legal or regulatory requirements, including PDPA and contractual requirements.
- Drive continuous improvement of security procedures, controls, and awareness programs.

2.2.5 Implementation, Monitoring, and Improvement of Standards

- A violation of this policy may result in disciplinary or remedial action, including the possibility of contract consequences.
- This policy shall be reviewed annually, or in the event of significant change within the Vendor or technology.
- The policy will provide for ongoing improvements to the ISMS based on regulations and feedback.

2.3 Statement of Applicability (SoA)

The Statement of Applicability (SoA) identifies what Annex A controls of ISO/IEC 27001:2022 are applicable to DSM IT (Pvt) Ltd, provides the justification for inclusion or exclusion, states implementation status, and maps each control to identified risks and relevant legal or regulatory requirements. The SoA also verifies that all controls chosen are in line with the organization's ISMS objectives and risk management context.

2.3.1 Selected Annex A Controls and Justification

•A.5.1 – Information Security Policies

- Inclusion Rationale: Establishes the foundation for information security management within the organization.
- Implementation Status: Draft policy developed; awaiting formal approval and

dissemination.

- Mapped Risks/Regulations: Non-compliance with internal obligations; supports PDPA and client data protection obligations.

•A.6.1 – Organization of Information Security

- Inclusion Rationale: Determines roles and responsibilities for accountability and management.
- Implementation Status: Roles defined, but responsibilities not yet completely documented.
- Mapped Risks/Regulations: Minimizes risk of unauthorized access or misuse; supports contractual requirements.

•A.8.1 – Asset Management

- Inclusion Justification: All critical assets are inventoried, classified, and protected.
- Implementation Status: Asset inventory partially documented; classification scheme in progress.
- Mapped Risks/Regulations: Protects sensitive client information and key IT infrastructure.

•A.9.2 – Access Control

- Inclusion Justification: Limits access to information by business need and role.
- Implementation Status: Minimal username/password controls in place; multi-factor authentication projected.
- Mapped Risks/Regulations: Prevents unauthorized access; supports confidentiality requirements.

•A.12.1 – Operational Security

- Inclusion Justification: Mitigates threats through secure operations and monitoring.
- Implementation Status: Antivirus and firewalls established; automated monitoring not yet established.
- Mapped Risks/Regulations: Reduces malware and network breach risks; aligns with ISO 27001 risk treatment objectives.

•A.17.1 – Information Security Continuity

- Inclusion Justification: Ensures business continuity in case of disruptions.

- Implementation Status: Backup processes in place; formal continuity plan under development.
- Mapped Risks/Regulations: Minimizes operational downtime; complies with client contractual and regulatory demands.

2.3.2 Excluded Controls and Justification

Some Annex A controls are excluded due to limited applicability:

- Controls for high-risk physical locations outside ISMS scope – no impact on core IT operations.
- Industrial process controls not implemented by DSM IT (Pvt) Ltd – not applicable to service-oriented IT operations.

2.3.3 Mapping to Identified Risks and Regulations

All the selected controls address explicitly risks from the initial risk register, including unauthorized access, data breaches, operational downtime, and regulatory non-compliance. With their implementation, DSM IT (Pvt) Ltd ensures compliance of its risk treatment plan with legal/regulatory stipulations, e.g., PDPA and contractual agreements with clients.

2.4 Risk Treatment Plan

The Risk Treatment Plan provides an official approach by which DSM IT (Pvt) Ltd can treat and handle identified information security threats in the initial risk register. The plan prioritizes risks, decides on appropriate treatment actions, assigns responsibilities, and decides on mechanisms for monitoring and reviewing effectiveness.

2.4.1 Prioritized Risks

•High-Priority Risks:

- Unauthorized access to sensitive client data
- Malware or ransomware attacks on IT infrastructure
- Loss of mission-critical business data during system crashes or accidental deletion
- Disruption of business during operation incidents

•Medium- and Low-Priority Risks:

- Minimum system downtime when it is maintained
- Non-critical process inefficiencies
- Low-impact threats with low visibility

2.4.2 Treatment Strategies Selected

- Avoid: Eliminate high-risk processes or unsupported application.
- Mitigate: Implement multi-factor authentication, encryption, firewall, endpoint monitoring, and secure settings.
- Transfer: Offload some data storage or processing to approved cloud providers.
- Accept: Monitor low-impact or low-probability risk without responsive action.

2.4.3 Timelines and Responsibilities

- IT Security Officer: Coordinate access controls and initiate mitigation steps – Timeline: 3 months
- Network Administrator: Install malware protection and monitoring tools – Timeline: 2 months
- IT Operations Manager: Coordinate backup procedure and data recovery – Timeline: 1 month
- Risk & Compliance Officer: Establish business continuity procedures – Timeline: 4 months
- IT Support Team: Coordinate low-priority risk and minor system maintenance – Ongoing

2.4.4 Monitoring, Review, and Effectiveness Evaluation

- Monitoring: Monitor the effectiveness of deployed controls, logs, and alerts.
- Review: Review quarterly the risk treatments and update the risk register.
- Effectiveness Evaluation: Track the effectiveness of treatment plans through KPIs, internal audits, and incident reports and improve as needed.

3. Conclusion

The ISMS Core Documentation for DSM IT (Pvt) Ltd presents a cohesive framework leading to the systematic management of information security, consistent with ISO/IEC 27001:2022, as part of business strategy and operating activities. DSM IT (Pvt) Ltd has executed steps to clearly define the ISMS scope, establish ISMS policies and objectives, apply relevant Annex A controls, and establish a Risk Treatment Plan showing risk mitigating action. In doing this, DSM IT (Pvt) Ltd recognizes the importance of safeguarding client data, protecting assets critical to the business and keeping the business operational. The documentation reflects the organization's prioritization of risk management led by its interests in avoiding, removing, mitigating, transferring and accepting risks along with timelines to completion, responsibilities on who will be completing the tasks and measures to evaluate if the actions taken, made a difference. In addition, the documentation shows top management have a clear commitment to resource allocation, assigning responsibility, developing roles and promoting an information security culture based on employee, contractor and third-party awareness of security functionality. The documentation reflects that DSM IT (Pvt) Ltd does not run the risk of using obsolete or dowdy and outdated thinking with respect to monitoring, reviewing and improving the ISMS for relevant risks of the future, growth, affordable regulations impacting the past from occurring again. As a component of the whole, it extends to documentation transparency if alternative ISMS are used by other organizations needing to comply with laws that impact DSM IT (Pvt) Ltd's scope. This ISMS Core Document contributes to better compliance with regulatory and legal contracts that otherwise affect confidence of clients and indirectly reduce risks of business disruption. Certainly, it enhances DSM IT (Pvt) Ltd reputation as a secure IT solutions provider, while indirectly expecting the future need of ensuring confidence of its clie